# IT Services Co. GRC Monitoring Project (Splunk)

A hands-on Governance, Risk and Compliance (GRC) project built in Splunk Enterprise. It analyses simulated authentication logs for a fictional company, identifies control failures, scores them in a risk register, and presents them on a dashboard.

> All names, IP addresses and events in this project are fictional.

## 1. Project Overview

- **Company (fictional):** IT Services Co.
- **Tool:** Splunk Enterprise 10.x (local install)
- **Data source:** `IT_Services_Co_Logs.csv` - simulated authentication logs, 180 events, October 2026
- **Splunk index:** `it_services_co`
- **Fields:** timestamp, username, role, employee_status, source_ip, login_result, mfa_used, system
- **Objective:** detect identity and access risks from log data, rate them, and recommend mitigations mapped to NIST CSF 2.0 and ISO/IEC 27001:2022.

## 2. Key Results

| Rating | Count |
|---|---|
| Critical | 1 |
| High | 2 |
| Medium | 1 |
| Low | 0 |

MFA control test: **FAILED** (3 of 10 active accounts, 30% failure rate).

# 3. Findings Summary

| ID | Finding | Rating | Score | Key evidence |
|---|---|---|---|---|
| R-01 | Terminated employees retain active access | Critical | 20 | 3 successful logins by 2 terminated users (bthomas x2, cdavis x1) from external IPs |
| R-02 | Brute-force attempt on admin account | High | 16 | 26 failed logins on asharma in about 3 minutes from 185.220.101.9 |
| R-03 | Accounts logging in without MFA | High | 16 | rpatel (Admin), tnguyen, pjones logged in without MFA |
| R-04 | Logins outside normal hours | Medium | 9 | 6 successful logins between 20:00 and 06:00, 3 by terminated users |
| CT-01 | MFA control test | Failed | - | 3 of 10 active accounts non-compliant |

Risk score = Likelihood x Impact (each 1-5). Low: 1-4, Medium: 5-9, High: 10-16, Critical: 17-25.

# 4. Splunk Searches Used

### Finding 1 - Terminated employee logins

```
index=it_services_co employee_status=Terminated login_result=SUCCESS
```

### Finding 2 - Failed login burst

```
index=it_services_co login_result=FAILURE | stats count by username,
source_ip | sort - count
```

### Finding 3 - Logins without MFA

```
index=it_services_co mfa_used=No login_result=SUCCESS | stats count by
username
```

### Finding 4 - After-hours logins

```
index=it_services_co login_result=SUCCESS | eval
hour=tonumber(strftime(_time,"%H")) | where hour>=20 OR hour<6 | stats count
by username
```

**Finding 5 - MFA control test**

```
index=it_services_co employee_status=Active login_result=SUCCESS | stats
count by username, mfa_used
```

**Retest (pass = zero results)**

```
index=it_services_co employee_status=Active login_result=SUCCESS mfa_used=No
| stats count by username
```

# 5. Dashboard

The **IT Services Co GRC Dashboard** gives a single view of authentication activity, failed logins, MFA usage and potential security incidents. See `/dashboard/` for the screenshot and PDF export.

# 6. Detailed Finding Write-ups

## R-01 - Terminated employees retain active access (Critical)

- **Risk:** Former employees can still reach company systems, which risks data theft or unauthorised changes.
- **Evidence:** bthomas (Developer) logged in twice and cdavis (Helpdesk) once, all successful, no MFA, from external IPs 203.0.113.45 and 198.51.100.77, reaching CLIENT_DB, FILE_SERVER and VPN between 6 and 11 October.
- **Likelihood 5 x Impact 4 = 20.**
- **Recommendation:** Disable both accounts within 24 hours, review what was accessed, and automate an HR-to-IT offboarding check plus a monthly terminated-user access review.
- **Mapping:** NIST CSF 2.0 PR.AA, ISO/IEC 27001:2022 A.5.18.
- **Owner:** IT Operations / IAM Lead.

## R-02 - Brute-force attempt on admin account (High)

- **Risk:** Repeated password guessing against a privileged account could lead to full compromise.

- **Evidence:** 26 failed logins against asharma (Admin) within about 3 minutes around 03:12 on 8 October, from external IP 185.220.101.9, all on ADMIN_PORTAL. 34 failed logins in the dataset overall.
- **Likelihood 4 x Impact 4 = 16.**
- **Recommendation:** Block the source IP, enable account lockout and rate limiting, restrict the admin portal to VPN, and create a Splunk alert for 5 or more failures in 5 minutes.
- **Mapping:** NIST CSF 2.0 DE.CM, ISO/IEC 27001:2022 A.8.5 and A.8.16.
- **Owner:** Security Operations Lead.

### R-03 - Accounts logging in without MFA (High)

- **Risk:** Password-only access is easily compromised through phishing or credential reuse.
- **Evidence:** 3 of 10 active accounts logged in without MFA: rpatel (Admin, 16 logins), tnguyen (Developer, 15) and pjones (Analyst, 14). 45 successful no-MFA logins in total.
- **Likelihood 4 x Impact 4 = 16.**
- **Recommendation:** Enforce MFA enrollment starting with the admin account and block password-only logins by policy.
- **Mapping:** NIST CSF 2.0 PR.AA, ISO/IEC 27001:2022 A.8.5.
- **Owner:** IAM Lead.

### R-04 - Logins outside normal hours (Medium)

- **Risk:** Off-hours access can indicate compromised credentials or insider misuse.
- **Evidence:** 6 successful logins between 20:00 and 06:00: rpatel x2, bthomas x2, cdavis x1, tnguyen x1. Three belong to terminated users and overlap with R-01.
- **Likelihood 3 x Impact 3 = 9.**
- **Recommendation:** Alert on after-hours logins to admin and client systems, and require manager approval or just-in-time access outside business hours.
- **Mapping:** NIST CSF 2.0 DE.CM, ISO/IEC 27001:2022 A.8.15 and A.8.16.
- **Owner:** Security Operations Lead.

### CT-01 - MFA control test (Failed)

- **Control tested:** All active employee accounts must use MFA.
- **Population:** 10 active accounts. **Failures:** 3 (30%). One failing account, rpatel, has admin privileges.
- **Result:** Control FAILED. Linked to R-03.

- **Retest criteria:** The retest search must return zero accounts, otherwise the finding stays open.

## 7. Repository Structure

```
splunk-grc-risk-register/
  README.md
  data/IT_Services_Co_Logs.csv
  risk-register/it_services_co_risk_register.xlsx
  screenshots/
    finding01_terminated_user_access.png
    finding02_failed_login_burst.png
    finding03_no_mfa_accounts.png
    finding04_after_hours_logins.png
    finding05_mfa_control_test.png
  dashboard/
    grc_dashboard.png
    grc_dashboard.pdf
  searches/splunk_searches.txt
```

## 8. How to Reproduce

1. Install Splunk Enterprise (free trial) locally.
2. Create an index named `it_services_co`.
3. Upload `IT_Services_Co_Logs.csv` with sourcetype `csv` into that index.
4. Run the searches in section 4 with the time range set to All time.
5. Build the dashboard from the saved searches.

## 9. Skills Demonstrated

Splunk SPL, log analysis, risk assessment and scoring, control testing, identity and access management, NIST CSF 2.0 and ISO/IEC 27001 mapping, dashboarding, and technical reporting.

## 10. Disclaimer

This is an educational project using fictional data. Framework mappings are suggested category-level references and should be verified against the official standards.

# Author

**Shivam** - LinkedIn | GitHub